

Policy-Aware Code Compliance Auditing Using Retrieval-Augmented LLMs

A system checking code repositories for compliance by matching source code against organization-specific and regulatory policies

Team

Rithvik Rajesh Matta	PES2UG23CS485
Rohan	PES2UG23CS489
Rishil A.J	PES2UG23CS482



Problem Statement

Ensuring software compliance with organizational policies and regulatory requirements is difficult as modern codebases scale and policies are often written in natural language.

Existing rule-based static analysis tools lack the flexibility and contextual understanding needed to accurately interpret and enforce these policies, leading to missed violations, high manual review effort, and increased compliance risk.

This gap creates compliance risks, delays development cycles, and increases operational costs, highlighting the need for an intelligent, policy-aware automated compliance auditing approach.

Use Case

Enterprise Regulatory Readiness:

Continuously scan large codebases to ensure alignment with evolving legal and internal policies, generating audit-ready compliance reports for security and legal teams.

- Secure Software Development (DevSecOps)
- Regulatory Compliance (HIPAA / GDPR / PCI-DSS)
- Business Rule Enforcement
- Audit & Governance Support
- Developer Education & Onboarding

Existing Work

I. S. Al Mandalawi, M. A. Mohammed, H. Maclean, M. C. Cakmak, and J. R. Talburt,
“Policy-Aware Generative AI for Safe, Auditable Data Access Governance,”

Novelty

- Introduces a policy-aware compliance auditing framework that interprets natural-language organizational policies rather than relying on rigid, predefined rules.
- Leverages Retrieval-Augmented Generation (RAG) to dynamically retrieve relevant policy clauses and reason over source code in context.
- Uses LLM-driven semantic code analysis to detect violations and generate human-readable explanations with policy references.
- Incorporates agentic workflows and prompt engineering to improve accuracy, transparency, and reduce hallucinations in compliance decisions.

Technical Aspects of GenAI Concepts Used

GenAI-powered, policy-aware code compliance system that automatically audits software repositories against organizational and regulatory policies.

1. It uses Retrieval-Augmented Generation (RAG) to interpret natural-language policies,
2. LLMs with neuro-symbolic reasoning to analyze code semantics.
3. Graph-based code analysis to detect deep compliance violations.

The system integrates into the development workflow to flag violations and generate clear, explainable compliance reports in real time.

Validation Metrics

1. Precision:

How many flagged violations are real

2. Recall:

How many real violations you catch

3. Policy Retrieval Precision:

Are the retrieved policies actually relevant to the code

4. Policy Recall:

Does the retriever find all required policies

Thank You

Violations

- 💰 1. Unauthorized Discounting or Pricing Logic
- 📄 2. Bypassing Approval Workflows
- 📊 3. Unauthorized Data Access Across Departments
- 📢 4. Violation of Marketing & Communication Guidelines
- 🌍 5. Regional / Legal Restrictions in Business Logic
- 🧠 6. Misuse of Customer Data for Analytics
- 👤 7. HR & Internal Access Policy Violations
- ⌚ 8. SLA & Time-Bound Business Rules
- 📄 9. Audit & Logging Policy Violations
- 📦 10. Vendor & Third-Party Usage Violations